

Déploiement Sécurisé de LAPS pour le compte DSRM

Construction du Bastion Tier 0 (Active Directory)

Ouvrez une console **Windows PowerShell (en tant qu'Administrateur)** et exécutez ces commandes :

1. Installez les binaires du rôle AD DS :

```
Install-WindowsFeature AD-Domain-Services -IncludeManagementTools
```

2. Promouvez le serveur en créant une nouvelle forêt. Attention, le système vous demandera de créer le mot de passe DSRM (ex: **AdminSecurite2026!**). C'est ce mot de passe que LAPS gèrera plus tard.

```
Install-ADDSForest -DomainName "formation.local" -InstallDns -Force
```

(Le serveur redémarrera automatiquement. Reconnectez-vous ensuite avec **FORMATION\Administrateur**).

Préparation de l'Active Directory pour LAPS

1.1 Extension du Schéma AD (Support du chiffrement)

Sur votre nouveau Contrôleur de Domaine, ouvrez une console PowerShell **en tant qu'Administrateur** et exécutez la commande suivante pour ajouter les attributs chiffrés LAPS à la base de données :

```
Update-LapsADSchema -Verbose
```

1.2 Création du groupe de confiance (Tier 0)

Seuls les administrateurs les plus critiques du domaine (Tier 0) auront le droit de déchiffrer cette porte dérobée.

1. Ouvrez la console **Utilisateurs et ordinateurs Active Directory (dsa.msc)**.

2. Allez dans le conteneur *Users*.
3. Créez un groupe de sécurité nommé *Admins_LAPS_Tier0*.
4. Ajoutez votre compte d'administration actuel (*Administrateur*) à ce groupe.

Sécurisation des ACLs (Le cœur de l'Audit ANSSI)

Nous devons modifier les droits (ACLs) sur l'Unité d'Organisation par défaut "**Domain Controllers**" (qui contient notre serveur).

2.1 Autoriser le DC à écrire son propre mot de passe

Toujours en PowerShell, tapez la commande suivante pour autoriser les serveurs de cette OU à mettre à jour leurs attributs LAPS :

```
Set-LapsADComputerSelfPermission -Identity "Domain Controllers"
```

2.2 Restreindre le droit de lecture et de déchiffrement

Nous donnons le droit exclusif au groupe *Admins_LAPS_Tier0* de lire les mots de passe LAPS des contrôleurs de domaine :

```
Set-LapsADReadPasswordPermission -Identity "Domain Controllers" -AllowedPrincipal "Admins_LAPS_Tier0"
```

Configuration de la GPO Tier 0 (Spécifique DSRM)

3.1 Création de la stratégie

1. Ouvrez la console **Gestion de stratégie de groupe** (*gpmc.msc*).
2. Faites un clic droit sur l'Unité d'Organisation **Domain Controllers** > **Créer un objet GPO dans ce domaine, et le lier ici...**
3. Nommez-le *GPO-SEC-LAPS-Tier0-DSRM*.
4. Faites un clic droit dessus > **Modifier**.

3.2 Paramétrage de Windows LAPS (Exigences de Sécurité)

Naviguez dans : Configuration ordinateur > Stratégies > Modèles d'administration > Système > LAPS

Configurez les paramètres suivants (Double-clic > Activé) :

- **Configurer le répertoire de sauvegarde des mots de passe** : Choisissez **Active Directory**.
- **Activer la sauvegarde du mot de passe pour les comptes DSRM** : Activé (C'est le paramètre clé qui indique à LAPS de cibler le DSRM au lieu d'un compte local).
- **Paramètres de mot de passe** : Activé (Complexité : Lettres, chiffres, symboles / Longueur : 20 caractères / Âge maximum : 30 jours).
- **Activer le chiffrement des mots de passe** : Activé (Essentiel pour parer les vols de base NTDS.dit).
- **Configurer les expéditeurs autorisés à déchiffrer les mots de passe** : Indiquez le domaine et le groupe sous la forme **FORMATION\Admins_LAPS_Tier0**.

Fermez l'éditeur de GPO.

PARTIE 4 : Validation et Preuve Cryptographique

4.1 Forcer la génération du mot de passe DSRM

1. Restez sur votre Contrôleur de Domaine.
2. Ouvrez une invite de commande (cmd) et forcez l'application de la GPO :

```
gpupdate /force
```

3. Forcez le moteur LAPS à s'exécuter immédiatement pour prendre le contrôle du DSRM (PowerShell Administrateur) :

```
Invoke-LapsPolicyProcessing -Verbose
```

4.2 Récupération via l'interface (Opérationnel)

1. Ouvrez **Utilisateurs et ordinateurs Active Directory** (**dsa.msc**).
2. Allez dans l'OU **Domain Controllers**.
3. Faites un clic droit sur l'objet de votre Contrôleur de Domaine > **Propriétés**.
4. Dans le nouvel onglet **LAPS**, vous pouvez voir le mot de passe de secours DSRM généré (car vous êtes membre du groupe Tier 0 autorisé).

4.3 Preuve d'audit ANSSI (La vérification "Sous le capot")

Nous allons prouver que même un administrateur du domaine non membre du groupe Tier0

(ou un attaquant ayant volé la base AD) ne peut pas lire ce mot de passe.

1. Ouvrez la console **Modification ADSI** (*adsiedit.msc*).
2. Connectez-vous au contexte d'appellation par défaut.
3. Naviguez jusqu'à l'OU *Domain Controllers* et trouvez l'objet de votre DC.
4. Faites un clic droit > **Propriétés**.
5. Cherchez le nouvel attribut : *msLAPS-EncryptedPassword*. **Il doit contenir un long bloc de données hexadécimales illisibles.**

Le mot de passe de secours (DSRM) de votre forêt AD est désormais rotatif, complexe, et chiffré cryptographiquement dans la base